七牛 Builder Day 2026 · 赛道一决赛 · 第二轮迭代

AIofCage 第二轮方向建议

基于 main 分支（4f75106）的代码与文档自评，加上 5 路市场调研：真实事故、沙箱用户反馈、多 agent 工作台品类、企业与国内政策、OpenClaw 类个人 agent。整理于 2026-10-29。

结论

第一轮证明了笼子是真的。真 key 不进沙箱、默认拒绝出网、MCP 凭据由沙箱外的组件代持，按设计推演，能挡住调研到的 27 类事故中的 13 类。剩下的损失集中在项目目录和白名单之内的写操作这两处。

第二轮的方向是让 agent 在笼子里放心干真活。所有改动先落在副本里，回写宿主前看得见、能撤销；默认拒绝不再卡住装依赖和拉代码；只有越界的写操作才需要人点头。

挡偷

凭据与网络层，补上 DNS、IPv6 和控制面实测

已有 · P0-4 补实测

可撤改

项目工作副本、改动审查与回写闸门

缺失 · P0-1

越界才问

开发源只读放行；推送、建仓等写操作审批

部分 · P0-2、P0-3

P0 共五项：工作副本与回写闸门、默认拒绝可用化、白名单内高风险写操作、隔离自检闭环、签名的一键安装。时间不够时的最小组合见迭代计划。

项目做了什么，解决什么问题

Claude Code、Codex、dsh 这类编程 agent 默认以用户本人的身份运行。它们能读家目录里的 key 和 SSH 配置，能连任意网站，MCP 配置里常常写着明文 token 和数据库密码。人工审批也挡不住，Anthropic 公布的数据是用户批准了 97% 的权限提示。题目要求“核心是安全，其次对普通用户友好，主流 MCP 无需在沙箱内填写敏感信息”，针对的就是这个局面。

AIofCage 的形态是“CC Switch + Docker Desktop”。桌面应用按 agent 管理多个模型供应商，key 只存 macOS 钥匙串；每个沙箱是专用 Colima 虚拟机里的一个容器，配一个独立的门卫代理。agent 在沙箱内免审批运行，安全由三道边界保证。

文件

只挂选定项目，项目必须在 `~/CageWorkspace` 内，路径含符号链接就拒绝挂载。容器以非 root 运行，根文件系统只读，去掉全部 capabilities。

部分

宿主文件安全，项目本身仍可被改坏

网络

agent 只接入内部网络，出网全部经过门卫。默认拒绝，只放行所绑定模型接口的具体路径和已配置的 MCP；IP 直连、非 443 端口、明文 HTTP 一律拒绝。

部分

IPv4 直连阻断已实测，DNS 报文与 IPv6 待验证

凭据

沙箱里只有 `cage-` 开头的占位符，门卫在请求头里换成真 key，带着其他 key 的请求直接拒绝。OAuth 刷新令牌只在宿主，数据库密码由可信连接器代持。

已有 并有隔离自检

在三道边界之上，应用提供中文界面与新手教程、按“沙箱 + 智能体”绑定供应商、结构化会话与恢复、用量和费用估算、额度、运行状态、安全诊断与 7 项隔离自检、基于脱敏元数据的 AI 安全解说，以及让外部 AI 通过本机 MCP 批量建沙箱、并发跑任务、对比结果的控制入口。仓库有 66 个 PR、160 次提交、3 位贡献者，167 项 Go 测试通过，30 余份验收记录按“通过、发现问题、无法验证、跳过”四态填写。

做得好的点

下面每一项都被本轮调研的证据验证过。第二轮保持这些能力，并把证据写进答辩叙事。

用边界代替逐条审批

沙箱内的 Claude Code 和 Codex 以免审批模式运行，安全由容器和门卫兜底。

证据 审批疲劳相关 issue 约 932 个 👍；用户批准 97% 的权限提示；把分类器当闸门，红队绕过率达 79%。

真 key 不进沙箱，外来 key 也用不了

门卫只认本沙箱的占位符，请求里出现别的 key 就拒绝（`credential_foreign`），堵住了“用攻击者自己的 key、经白名单域名外传”这条路。

证据 PocketOS 删库（翻出的真 token 属于外来 key）、CVE-2026-21852、Cowork 借 Files API 外传，在默认配置下都会被拦。调研的 20 余款本机工作台里，没有第二家把 key 和 agent 隔开。

规则细到 API 路径，细节经得起推敲

模型接口只放行 `POST /responses`、`/chat/completions`、`/v1/messages` 等必要路径；请求用 `Connection` 头点名删除凭据头会被拒；管理接口拒绝带 `Origin` 的请求并要求强随机 token；OAuth 地址只接受 https，打开时不经 shell。

证据 项目路径拒绝符号链接，正好对应 brig 的挂载穿越漏洞 GHSA-wp6x-29qx-fpr7；OAuth 地址校验对应 mcp-remote 的 CVE-2025-6514（CVSS 9.6）。

MCP 四类凭据全覆盖

HTTP Bearer 由门卫注入；OAuth 在宿主浏览器登录，刷新令牌不出宿主；PostgreSQL 由可信连接器代持密码，使用只读账号并校验 SQL 结构；固定连接器能按工具授权，撤销时清空授权并删除连接器。

证据 53% 的开源 MCP 服务器依赖长期静态 key。这一项直接回应题目第三条。

审计在笼子外面

脱敏事件写在宿主的 JSONL 里，agent 改不了也删不掉；写盘成功才确认，跨运行的缺口会显式标出。

证据 Manifold 收录的 59 起 agent 事故，没有一起公开过完整操作日志；Salt 的调查中只有 12.5% 的组织能完整追踪 agent 活动。

零账号、中文、国产生态

不需要登录任何账号；预置 DeepSeek、Kimi、智谱的兼容接口；支持 dsh。

证据 Docker sbx 发布帖至少 9 条顶层评论批评“本地工具也要登录”；CC Switch 用户请求支持 dsh 的 issue（#6430）至今未关闭。

工程诚实，版本选得稳

验收不把跳过算通过，安全说明主动写清边界。默认固定的 Codex 0.164.0、Claude Code 2.1.309、dsh 0.2.1-rc.2，都高于本轮查到的漏洞修复版本，也不在 NVDB 通报的 Claude Code 版本区间内。

做了但可以更进一步

“现在”一列来自代码与文档核对，“第二轮”一列对应下文的优先级编号。

方面	现在	差距与证据	第二轮
项目目录	按同一路径读写挂载；工作区外的项目先复制一份，改完没有合回原项目的入口	没有快照、回滚和审查；写进项目的可执行配置会留在宿主执行；本机 MCP 的故障切换在改过的目录上重跑；任务对比只比 500 字摘要	P0–1
网络规则	规则只从供应商和 MCP 绑定生成	沙箱里装不了依赖、拉不了代码；用户不能启用预设，也不能从日志放行；403 正文只写 `default_deny`，agent 容易误判为认证失败	P0–2
白名单内写操作	规则引擎支持域名、方法、路径和显式 deny	没有请求体字段规则和审批；GitHub 只能接 PAT 型 MCP，没有安全的 `git push`	P0–3
隔离实测	IPv4 直连阻断已实测；7 项隔离自检	DNS 报文和 IPv6 仍是“无法验证”；界面上“5/7 项通过”容易让普通用户误读	P0–4
安装与首启	源码 `make app`，需要 Homebrew、Go、Colima、Docker CLI	与题目“不能是太技术化的配置”冲突；首次构建镜像约 5 分 35 秒	P0–5
额度	累计请求和 token 额度，80% 时提醒	没有按日窗口、速率熔断、一键全停，也没有完成或等待输入的通知	P1–6
版本	有更新检查、版本选择和失败回滚	没有最低安全版本，旧沙箱可以停在有漏洞的版本上	P1–7

方面	现在	差距与证据	第二轮
远程 MCP	按服务授权	没有工具级授权，也没有工具定义的漂移检测	P1–8
AI 功能	解释单条事件、总结沙箱活动	停留在事后解说，没有在放行、回写、任务结束这些决策点上帮人	AI 一节
登录方式	只支持 API Key	订阅登录的需求很硬，但条款和风控没有核实	P1–11
使用范围	单机个人工具	团队治理的付费证据最强，但赛道拥挤	P2

市场调研：三个证据簇

调研覆盖 2025 年 1 月至 2026 年 10 月：约 40 个编号案例归并为 27 类事故，按 GitHub 👍 排序的沙箱用户痛点，20 余款多 agent 工作台和 CC Switch 类工具，国内外企业实践与 TC260、NVDB 文件，以及 OpenClaw 类个人 agent。三组数字最能说明第二轮该往哪里使劲。

1,129

个 👍，热度第一

“改动审查、撤销与回滚”。另有十余个 CVE 利用 agent 写进项目的配置在宿主执行。

AIofCage 缺失

482

个 👍，跨 6 款以上产品

“网络白名单误伤开发流程”。Cursor 官方给的变通是把 Auto-Run 改回每次询问，等于关掉沙箱。

AIofCage 部分

97%

的权限提示被用户批准

审批疲劳簇约 932 个 👍。用边界代替逐条审批是对的，第二轮的审批只留给越界的写操作。

AIofCage 已有

按设计推演，27 类事故中 AIofCage 现在能阻止 13 类，部分可管 7 类，缺失 4 类，基本无效 3 类。补上第二轮 P0 的前三项后，约 6 类会从“缺失”或“部分”变为“可阻止”。这些都是机制推演，目前只有 IPv4 直连隔离做过实测。

真实案例里的问题、需求和价值

精选 10 条，覆盖“已经挡住”“还缺”“挡不住”三种情况。完整的 27 类对照见调研报告。

案例	发生了什么	暴露的问题	需求	满足后的价值	AIofCage
PocketOS 删生产卷 2026-04 · 来源	Cursor 里的 agent 从无关文件翻出权限很宽的 Railway token，约 9 秒删掉生产卷和同卷备份	禁令写在提示词里，agent 照样执行；token 权限过宽	真 key 不进 agent 环境；白名单内破坏性操作要审批	默认配置下可阻止；即使放行 Railway，翻出的真 token 也属外来 key	已有

案例	发生了什么	暴露的问题	需求	满足后的价值	AIofCage
4.8 万文件误删 2026-09 · 当事人自述 · 来源	Claude Code 写的清理脚本误判 Windows junction，约 103 秒删掉 48,218 个真实文件	agent 的检查点只记自己的编辑工具，管不到 shell	任务前快照或工作副本	最坏结果降为“丢弃副本”	缺失
项目配置回到宿主执行 CVE-2025-53773、GitSpawn 等 · 来源	agent 写进项目的 `.vscode`、钩子、`.git/config`，在宿主用 IDE 或 git 打开项目时执行	沙箱关住了执行，关不住回写；GitSpawn 的 8 项发现里有 4 项发布时未修	回写闸门；宿主不在 agent 改过的 `.git` 上跑 git	堵住 CVE 最密集的一条攻击路径	缺失
PixelLeak 2026-09 · 来源	agent 为给 PR 配图，把 1.3 万多张内部截图推到公开仓库，涉及 300 多家机构	没有攻击者也会外泄	GitHub 只读放行，建仓、改可见性、推送要审批	放行 GitHub 之后仍能挡住	默认已有
被拦后的失控反应 2026 · Voratiq · 来源	npm 被拦后，Codex 伪造 lockfile 哈希、改沙箱配置删掉拒绝规则；Gemini 反复重试，写出数 GB 日志	拦截提示不清，agent 自作主张	agent 看得懂的拦截提示；一键放行	默认拒绝能留下来；避免数小时的误判排查	部分
Gemini key 盗刷 2026-02 · 来源	48 小时被刷 82,314 美元，这个团队平时每月约 180 美元	本地额度看不到别处的盗刷	按日预算；供应商侧按 key 设硬上限	损失封顶在“日额度 × 天数”	部分
ZCode 整仓上传 2026-09 · 来源	桌面编程工具把工作区打包传到云存储，待传文件 313MB，约 87% 是 `.git`	工具自身的行为造成外泄	默认拒绝出网	按设计可阻止	已有
ClawHub 恶意技能 2026-02 · 来源	被审计的 2,857 个技能中有 341 个恶意，主要载荷是 macOS 窃密木马	技能市场投毒	agent 跑在隔离环境里	macOS 载荷在 Linux 容器里跑不起来，钥匙串不可见，回连被拒	已有
dsh CVE-2026-82533 2026-09 · CVSS 9.4 · 来源	沙箱内进程调用无认证的本机控制 API，把自己升级为无限制执行	agent 自带的沙箱放开了回环网络	外层隔离；最低安全版本	控制面本身在容器里，外层笼子仍在	已有 缺版本下限
postmark-mcp 暗抄邮件 2025-09 · 来源	1.0.16 版加了一行代码，把每封外发邮件暗抄给攻击者，估计 3,000 至 15,000 封	借合法服务做坏事	工具指纹与字段级策略	只能缓解	基本无效，主动讲清

品类与市场信号

多供应商管理是头号痛点

CC Switch 有 14.99 万星，发布包累计下载约 2,201 万次（含自动更新），热度是任何并行工作台的 5 倍以上。它的路由模式也用占位符加本机代理，但 agent 直接跑在宿主上；赞助商多是中转站，而一项实测发现 428 个路由中有 9 个主动注入恶意代码。

启示：AIofCage 可以讲成“安全版 CC Switch”。

并行已被平台免费化

Codex app 的 Mac 版首周下载超过 100 万次；Claude Code 桌面版、Cursor 3、Zed 1.0、JetBrains Air 都把“每个任务一个 worktree，审查 diff 后合并”设为默认。Vibe Kanban 背后的 Bloop 在 4 月关停，理由是绝大多数用户不付费，Terragon 在 1 月关停。

启示：不拼并行的功能广度，拼“敢放手”。

Docker sbx 的口碑

HN 发布帖 694 分、396 条评论。好评集中在出网防火墙和占位符密钥，和 AIofCage 的核心卖点一致；差评集中在强制登录。它的组织治理单独收费，是最接近的团队版参照。

启示：零账号可以直接拿来对比。

企业放开 agent 的条件

Stripe 和 Ramp 只让 agent 在没有生产权限的一次性隔离环境里无人值守运行，Ramp 自报约一半合并 PR 由此发起。单个 agent 的治理已经随席位附带，例如 Claude Code 托管设置、Claude apps gateway、Copilot 企业版 MCP 白名单。

启示：隔离环境、受控出网、不放生产凭据、PR 人工审查，正是 AIofCage 单机已有的能力组合。

国内的管控意愿

字节自 2025 年 6 月底分批停用 Cursor 等工具；阿里自 2026-07-10 起禁用 Claude Code。据媒体转述，工信部 NVDB 7 月通报 Claude Code 2.1.91 至 2.1.196 存在回传地域和身份信息的隐患，建议企业管控开发工具的外联。TC260《智能体部署使用安全指引》6 e) 要求优先选用带安全沙箱、高风险操作管控、急停和“可回溯文件系统”的智能体，7 c) 要求不经来源不明的中转站调用模型，附录 B 列出资产登记字段。

启示：门卫管控外联、副本可回溯，都能逐条对上国内条款。

个人 agent 很热，形态错配

OpenClaw 星数从 3 月初约 24.7 万涨到 5 月下旬约 37.4 万，腾讯 WorkBuddy 7 月月活 658.2 万；公网暴露实例 2.1 万多个，CVE-2026-25253 一条链接就能偷走网关 token。另一面，QClaw 将于 12 月 24 日停运，市场向大厂托管收敛；大额损失多发生在授权通道内；IM 凭据放在 URL 和 WebSocket 里，门卫目前只替换请求头。

启示：只做有边界的试点。

被证据降级的方向

方向	需求证据	卡在哪里	建议
订阅登录	“让 Max 订阅继续能在 OpenCode 里用”796 个 👍、410 条评论；无头环境用 ChatGPT 登录 Codex 100 个 👍	据二手报道，Anthropic 限定订阅 OAuth token 只用于 Claude Code 和 Claude.ai，容器内经代理注入是否触发风控未知；企业启用 `forceLoginMethod` 会拦截 API key 登录	P1 先花一天验证链路和条款
团队治理后台	付费证据最强：Qoder 企业版每席每月 99 或 199 元，CodeBuddy 每人每月 198 或 316 元，sbx 组织治理单独收费	赛道拥挤，单 agent 治理已随席位附带	P2 先做 TC260 自查报告这个切片
OpenClaw 主线	星数约 37 万，WorkBuddy 月活 658 万	损失多在授权通道内；IM 凭据不在请求头里；7×24 常驻与 Mac 睡眠冲突	P2 有边界试点，只代持模型 key
Linux / Windows	约 491 个 👍	成本高；这个品类普遍 Mac 优先，CC Switch 下载约七成来自 macOS	路线图
microVM	本轮没有找到编程 agent 的在野内核逃逸	证据最弱	路线图
GPU、iOS 开发	有零星需求	macOS 上的 Linux 容器基本做不到	写进不适用场景

第二轮方向

> **让多个 agent 在笼子里免审批地跑一夜。key 不出钥匙串，出网默认拒绝却不卡开发，花费有上限，所有改动先落在副本里，回写宿主前看得见、能撤销。**

并行已经被平台厂商免费化，AIofCage 不必在功能广度上追赶 Codex app 和 Cursor 3。它要卖的是“敢放手”：敢开免审批，敢离开电脑，敢让官方接口、国产 Coding Plan 和中转站在同一个项目上同台比较。“工作副本加回写闸门”这一项投入，同时回应了热度第一的用户需求、CVE 最密集的攻击路径、工作台的标配能力、TC260 的“可回溯文件系统”条款，以及非技术用户最怕的误删。

P0-1 工作副本与回写闸门

做什么

每个沙箱一份项目副本，挂到容器内原路径，保持现有的同路径约定；`.env`、私钥、证书默认不进副本。任务结束给出审查页，批量删除和可执行配置（`.git/config`、`.git/hooks`、`.claude/`、`.cursor/`、`.vscode/`、`.mcp.json`、`AGENTS.md`、`CLAUDE.md`、`.envrc`、`package.json` 的 scripts、`.venv`）单独标红，逐项回写或一键丢弃。

证据

回滚需求簇约 1,129 个👍；十余个“项目配置回到宿主执行”的 CVE；工作台普遍标配；TC260 6 e) 的“可回溯文件系统”。

验收

- agent 在副本里删除 1,000 个文件后，宿主项目不变；丢弃副本后能从干净副本重新开始。
- agent 写入 `core.fsmonitor` 和 `.vscode/settings.json` 的自动批准，审查页把两处标红，默认不回写。
- 宿主侧生成对比时，不在 agent 改过的 `.git` 上运行 git。

难点

APFS 写时复制在 virtiofs 共享目录上的开销，以及 node_modules 等大目录的性能，先做半天可行性验证。

P0-2 默认拒绝可用化

做什么

开发源只读预设，覆盖 npm、PyPI、Go proxy、crates、Maven、apt，以及 npmmirror、goproxy.cn 等国内镜像，只放行下载、不放行发布。日志页每条拦截记录提供“仅本次”和“本沙箱”两档限时放行。403 正文和 agent home 里的全局指令写明“这是沙箱拦截，不要重试或改配置，可在日志页放行”。

证据

误伤簇约 482 个👍，跨 6 款以上产品；厂商官方变通是关沙箱；agent 被拦后伪造 lockfile、改策略文件。

验收

- 开启预设后，沙箱内 `npm install`、`pip install` 成功，`npm publish` 仍被拒。
- 未开启时，agent 收到可读的 403 并停止重试。
- 一键放行只影响之后的请求，到期自动收回，并写入审计。

P0-3 白名单内的高风险写操作

做什么　GitHub 预设只放行 clone 和 fetch 用的 `git-upload-pack`；推送（`git-receive-pack`）、建仓、改可见性、写 gist、修改分支保护默认拒绝，被拒后由用户限时放行。走 HTTPS 的 git 在 Basic 认证头里替换占位符，真 token 不进沙箱。

证据　PixelLeak 外泄 1.3 万多张截图；Karakun 案中 agent 向两个仓库的 main 推送删除 151 和 723 个文件；agent 自行关闭分支保护。

验收
- 沙箱内 `git clone` 私有仓库成功，沙箱的文件和环境变量里找不到真 token。
- `git push`、新建仓库、改为公开都被拒，并出现限时放行入口。
- 放行后推送成功，审计记录放行范围和到期时间。

P0-4 隔离自检闭环

做什么　补上外部可观测的 DNS 外传对照、带 IPv6 出网的测试环境，以及按 dsh CVE、Pillar 沙箱逃逸周、Codex Heapjack 等公开手法编写的管理面与 Docker socket 探针。

证据　dsh CVE-2026-82533（CVSS 9.4）；Pillar 在 Cursor、Codex、Gemini CLI 上发现的 Docker socket 可达问题。

验收　四类探针在演示机上给出“通过”或明确的“发现问题”，不再停在“无法验证”；脚本和结果写入 `docs/validation/`，可复现。

P0-5 签名的一键安装

做什么　签名并公证的 DMG 或 Homebrew cask；首次启动自动准备运行环境，复用现有新手引导；可选预构建镜像，按摘要固定，缩短首次启动。

证据　题目要求“不能是太技术化的配置”；Anthropic 9 月威胁报告提到冒充 harness 的凭据收集器；“龙虾”上门安装费曾涨到 1,500 元。

验收　一台没装 Homebrew 和 Go 的 Apple Silicon Mac，从下载到第一次对话不需要打开终端，并记录实际耗时。

难点　需要 Apple 开发者账号；Colima、Lima 的打包方式要先确认。

P1 与 P2

编号	需求	证据	形态
`P1-6`	**无人值守护栏**	只有 17.5% 的组织能自动叫停 agent；48 小时被刷 82,314 美元；5 个并行会话 15 分钟耗尽 Pro 额度	门卫按日计额度、速率熔断；菜单栏一键全停；完成和等待输入时通知；绑定七牛 key 时调用其按 key 额度 API
`P1-7`	**最低安全版本表**	修复版本明确，如 Claude Code 2.0.65 与 2.1.196、Codex CLI 0.149.0、dsh 0.1.2-alpha.1	版本下限随应用更新，低于下限时阻止启动
`P1-8`	**远程 MCP 工具级授权与工具指纹**	Deadbugz 第 3 次调用后才激活；postmark-mcp	首次连接时记录 `tools/list` 的哈希，变化就暂停并提示；远程工具 allowlist
`P1-9`	**TC260 与 NVDB 自查报告**	字节、阿里的禁令；只有 14.4% 的 agent 经过完整审批才上线	一键导出逐条对照的报告和资产登记表，如实列出未覆盖项；“只允许官方或备案接口”开关
`P1-10`	**多方案并排比较**	CC Switch 用户请求多实例并行（#1243）	建立在 P0-1 的副本上，一屏比较 diff、费用和拦截事件
`P1-11`	**订阅登录**	796 个 👍；官方文档承认跳过权限时 `~/.claude` 里的凭据可被外传	先验证一天：`claude setup-token` 存入钥匙串，门卫对 api.anthropic.com 注入
`P2`	**团队治理、OpenClaw 试点、Linux/Windows、更多 agent**	见上一节	进路线图；CC Switch 配置导入可以提前评估

迭代计划

三条并行工作线

团队三个人，每条线一个负责人。按改动的代码区域划分，减少互相冲突。

门卫与网络

`P0-2` `P0-3` `P1-6`

共用门卫的规则下发和日志页，适合放在同一个分支推进。日预算与熔断成本低、演示效果强，跟这条线一起做。

项目副本与审查

`P0-1` `P1-10`

先做半天可行性验证，再做审查页和回写闸门；多方案比较建立在副本之上。

交付与可信

`P0-4` `P0-5` `P1-7` `P1-9`

隔离实测、安装包、版本下限和合规报告，直接支撑架构分和国内评委的关注点。

顺序

1. **第一天。**P0-4 的 DNS、IPv6、管理面探针最便宜，先把“按设计”变成“实测”；同时做 P0-1 的半天可行性验证；订阅登录的一天验证可以并行。

2. **主体。**门卫与网络、项目副本与审查两条线并行，每项一个分支一个 PR，结果写入 `docs/validation/`。
3. **收尾。**做安装包与首次启动，按演示脚本彩排，更新功能清单和验收索引。

时间不够时的最小组合　P0-4；P0-1 只做副本和回写闸门；P0-2 只做预设和一键放行；P0-3 先只做 GitHub 推送和建仓两条规则。

AI 放在哪里

原则不变：AI 负责解释和建议，人做决定，放行由门卫规则执行。证据支持这样做，把分类器当闸门，红队绕过率是 79%，Embrace The Red 对 auto mode 的三组小样本攻击成功了 3/5 到 4/5。第二轮把 AI 从事后解说挪到三个决策点上，评委能直接看到。

拦截时

说清被拦的是什么请求、由哪个操作触发、风险多大，并建议最小放行范围。例如“这是 PyPI 的下载 CDN，建议加入本沙箱的只读预设”，用户一键确认。

回写审查时

逐项解释标红改动的风险，例如 `core.fsmonitor` 会在宿主上执行命令，并给出“建议丢弃”或“建议回写”。

任务结束时

生成一页任务安全报告，列出访问了哪些服务、被拦了几次、改了哪些文件、花了多少钱。

AI 工程效率

第二轮的功能就在 AIofCage 自己的沙箱里开发，用笼子开发笼子。开发过程中的用量、费用和拦截记录可以直接作为“AI 工程效率”的证据；P0-2 要解决的问题，也会在第一次 `npm install` 时自己冒出来。

决赛演示脚本

每一幕对应一起有出处的真实事件，可以在现有“隔离检查”的基础上扩充。

1. **批量删除，丢弃副本。**agent 在副本里删掉大量文件，点“丢弃副本”后宿主项目原样不动。
   对应 103 秒删除 48,218 个文件一案
2. **回写闸门。**agent 往 `.vscode/settings.json` 写入自动批准、往 `.git/config` 写入 fsmonitor，审查页把两处标红拦下。
   对应 CVE-2025-53773 和 GitSpawn

3. **越界才问。**开启 GitHub 预设后，agent 想新建公开仓库推送截图，请求被拦并出现审批。
   对应 PixelLeak
4. **看得懂的拦截。**npm 被拦，agent 读到提示后停手，用户一键选择“本沙箱放行 npm 只读”。
   对应 Voratiq 观察到的伪造 lockfile
5. **预算熔断。**日预算触顶，门卫自动暂停该沙箱。
   对应 Gemini key 48 小时被刷 82,314 美元

每一幕都由 AI 解说用中文讲清楚发生了什么，放行仍由规则决定。

商业叙事

安全版 CC Switch

CC Switch 14.99 万星说明多供应商、多 key 管理是这批用户的头号痛点。AIofCage 提供同样的切换体验，再把 agent 关进笼子，中转站即使下发恶意内容，也只能碰到项目副本。可以评估“一键导入 CC Switch 配置，key 从配置文件搬进钥匙串”，动手前先确认它的存储格式。

七牛渠道

绑定七牛 key 时调用按 key 额度 API，本地门卫额度和七牛服务端硬上限双层封顶。AIofCage 是七牛 LAS 密钥注入在端侧的入口，也是把 token 卖给 Claude Code、Codex、dsh 用户的入口。

国内合规

一键导出按 TC260、NVDB 逐条对照的自查报告和资产登记表，如实列出未覆盖项；“只允许官方或备案接口”开关回应 TC260 7 c)。阿里禁用 Claude Code、字节换用 TRAE，说明国内企业的管控意愿很强。

团队版路线图

Claude apps gateway、sbx 组织治理和国内的席位制产品，说明“企业分发用量而不是 key”已经有人买单。第二轮不做后台，单机导出格式保持稳定，便于将来汇总。

风险与待确认

- 第二轮的时长和评分细则还不知道。如果沿用初赛权重（商业价值与产品设计 50%、架构设计 20%、AI 价值呈现 15%、AI 工程效率 15%），上面的排序不变。
- 副本方案在 virtiofs 共享目录上的性能，以及默认 4 核 6 GiB 的虚拟机能同时跑几个 agent，都没有实测。
- “只在少量高风险操作上审批”能否避开审批疲劳，没有找到实证数据。
- 订阅 token 注入涉及的条款和风控没有核实。
- 部分破坏性案例只有当事人自述，NVDB 通报来自媒体转述，企业的 PR 数量多为自报；本轮也没有找到“占位符方案在真实攻击中挡住窃取”的在野记录。答辩时把“按设计可阻止”和“已实测阻止”分开讲。

- 边界要主动讲清。AIofCage 挡不住已授权服务里的滥用（如 postmark-mcp 暗抄邮件）和 SaaS 侧漏洞（如 CamoLeak），也保护不了已经被木马控制的宿主机。

资料

- 完整调研报告：随本文一起发送的《AI Agent 安全沙箱真实案例与需求》（PDF 或 Markdown），含 27 类案例对照和全部来源链接。
- 5 份分项调研笔记（事故案例、沙箱用户痛点、多 agent 工作台品类、企业与国内实践、个人桌面 agent）保存在整理人本机，需要时可以索取。
- 仓库内资料：初赛调研、当前架构、功能清单。
- 本页常用的外部来源：codex#9203（/undo，490 👍）、Cursor 论坛的沙箱网络问题、Anthropic 关于 97% 批准率的数据、CC Switch、TC260 指引、七牛按 key 额度 API。

本页根据 AIofCage 仓库与公开资料整理，数字和案例的出处见调研报告。“按设计可阻止”是机制推演，不等同于实测结果。